

Recap

Mail servers are the core components of email services

Software agents for the submission, transfer and delivery of mail messages
& temporary and permanent storage areas for storing the messages

Software agents are organized according to a client/server model

SMTP protocol is the application layer protocol used by clients and servers to communicate (over a persistent TCP connection)

Concept of SMTP session consisting of commands sent by clients (in a fixed order) and responses sent by servers

SMTP transfers mail objects that consist of an envelope and the content, i.e., header lines and body

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

19

Example

```
Return-Path: [REDACTED]@unipv.it>
Received: from [10.87.152.123] ([192.167.87.231])
    by smtp.gmail.com with ESMTPSA id a640c23a62f3a-ac31485bd4dsm204789166b.81.2025.03.14.03.24.25
    for [REDACTED]@universitadipavia.it>
    (version=TLS1_3 cipher=TLS_AES_128_GCM_SHA256 bits=128/128);
    Fri, 14 Mar 2025 03:24:25 -0700 (PDT)
Content-Type: multipart/alternative; boundary="-----700xZypkLaHd0yCYcEPjCWF0"
Message-ID: <02068d3b-4e92-4ab5-8099-b96687b25d39@unipv.it>
Date: Fri, 14 Mar 2025 11:24:24 +0100
MIME-Version: 1.0
User-Agent: Mozilla Thunderbird
Subject: Re: Thesis
To: [REDACTED]@universitadipavia.it>
References: <CADfXdbSWFZpL+-uMmdu2wyZEhLP-z6GotApsbgLArgPodqN5w@mail.gmail.com>
    <CADfXdbTU=rV5Ad2y=1n2ZQmHPGeC4FoGOVmVK0x6y+_3d00rxQ@mail.gmail.com>
    <72bb8e03-e047-4b24-b4f7-0c30ccb995b6@unipv.it>
    <CADfXdbTqB6ZYd=uPn=h-h0nZFSEHBrAFq2CVuehD+tPL087EYQ@mail.gmail.com>
Content-Language: it, en-US
From: [REDACTED]@unipv.it>
```

Multipurpose Internet Mail
Extension [RFC 2045]

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

20

Notification mechanisms

Notification mechanisms are used to make SMTP reliable

Delivery Status Notification (DSN) is the standard used for notifications [[RFC 3464 "An Extensible Message Format for Delivery Status Notifications"](#) published in 2003]

The sender is notified by the MTA in case of temporary or permanent delivery failure of an email message (e.g., recipient mailbox, mail server)

DSN implemented as SMTP extensions to message envelope:

MAIL FROM: <...> **RET=[HDRS , FULL]**

RCPT TO: <...> **NOTIFY=[SUCCESS , FAILURE , DELAY , NEVER]**

The "return receipt" is sent to **reverse-path** specified in the envelope (also specified in the **Return-Path** header field)

Some MTAs do not implement notifications through DSN for security reasons (e.g., fake receipts)

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

21

Security

Security risks have increased in the years and keep increasing

Many security threats affect email services (e.g., spam, scam, phishing) often used as the attack vector

Security by design was not an SMTP design principle

Very often threats leverage SMTP weaknesses (combined with user behavior)

Threats might also exploit vulnerabilities of the technological infrastructure due to MTA misconfigurations (e.g., relaying)

Providers have to protect their email services and make them trustworthy

- Ensure privacy, confidentiality and integrity of mail objects
- Identify and mitigate security threats
- Reduce the volume of "unwanted/malicious" messages

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

22

Privacy/confidentiality/integrity

To protect mail objects in transit (against tampering), it is necessary to protect the communication channel between SMTP clients and servers (i.e., MUA > MSA and MTA > MTA)

SMTP service extension based on TLS provides private communications between clients and servers [[RFC 3207 “SMTP Service Extension for Secure SMTP over Transport Layer Security”](#) published in 2002]

```
Received: from o16.sg.zoom.us (o16.sg.zoom.us. [149.72.122.209])
  by mx.google.com with ESMTPS id 137-20020a25038f000000b0b9dbb4f87easi12528828ybd.347.2023.05.03.23.45.35
  for <XXX>
  (version=TLS1_3 cipher=TLS_AES_128_GCM_SHA256 bits=128/128);
```

```
Received: from f72.mxout.mta4.net (f72.mxout.mta4.net. [96.45.68.72])
  by mx.google.com with ESMTPS id s16-20020a05620a031000b0074e0df8ca0dsi3695672qkm.357.2023.05.09.01.41.00
  for <XXX>
  (version=TLS1_2 cipher=ECDHE-ECDSA-AES128-GCM-SHA256 bits=128/128);
```

```
Received: from boba-fett.infotel.it (boba-fett-02.infotel.it. [62.173.164.47])
  by mx.google.com with ESMTP id w19si3972225edc.370.2021.05.19.11.20.43
```

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

23

Privacy/confidentiality/integrity (cont'd)

An unsecure TCP connection can be upgraded to a secure connections based on TLS (opportunistic TLS)

STARTTLS is an SMTP command issued by the client that informs the server that it wants to use a secure connection

SMTP servers listen on port 587

STARTTLS can be used by SMTP clients for message submission whenever authentication is required (**AUTH** extension)

```
Received: from [10.87.230.221] ([192.167.87.231])
  by smtp.gmail.com with ESMTPSA id 4fb4d7f45d1cf-5733bea65c0sm11698397a12.10.2024.05.17.03.49.31
```

SMTP clients and servers can also use TLS since the beginning

SMTP servers supporting TLS listen on port 465

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

24

SMTP session

```
S: <waits for connection on TCP port 25>
C: <opens connection>
S: 220 mail.imc.org SMTP service ready
C: EHLO mail.example.com
S: 250-mail.imc.org offers a warm hug of welcome
S: 250-8BITMIME
→ S: 250-STARTTLS
→ S: 250 DSN
C: STARTTLS
S: 220 Go ahead
C: <starts TLS negotiation>
C & S: <negotiate a TLS session>
C & S: <check result of negotiation>
C: EHLO mail.example.com
S: 250-mail.imc.org touches your hand gently for a moment
S: 250-8BITMIME
S: 250 DSN
```

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

25

Privacy/confidentiality/integrity: summary

SMTP is not an end-to-end mechanism

TLS has to be selected on a single hop basis

This does not ensure privacy, confidentiality and integrity of the mail object from the sender to the recipient mailbox

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

26

SMTP weaknesses

The main source of security risks is spoofing (i.e., IP address, message envelope and content)

What can be spoofed in an email message:

1. Domain name associated with **EHLO** command
2. Sender's email address specified in the envelope **MAIL FROM:<>**
3. **Received** header fields (inserted by MTAs and attackers)

Measures to fight spoofing and the associated security threats are implemented by MTAs (and completely transparent to the users)

Specific filters (e.g., anti-spam, anti-malware software) are applied to analyze the content of email messages (also provided by MUAs)

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

27

Simplest measure to fight spoofing

Reverse lookup of the sender IP address using the **PTR** Resource Record

Implemented by the recipient Mail Server that checks

1. whether there is a **PTR** RR associated with source IP address
2. whether the name provided by the lookup phase corresponds to the name indicated in the email message

```
Received: from mail.pldata.cz (mail.pldata.cz. [88.146.100.179])  
by mx.google.com with ESMTPS id z15si1540347wrs.38.2021.05.12.16.20.49  
for <mcc@unipv.it>  
(version=TLS1_2 cipher=ECDHE-ECDSA-AES128-GCM-SHA256 bits=128/128);
```

Query of type **PTR** for **179.100.146.88.in-addr.arpa**

179.100.146.88.in-addr.arpa IN PTR mail.pldata.cz.

```
Received: from [169.254.123.185] (unknown [105.161.106.214]) by  
45-158-14-27.hostlab.net.tr (Postfix) with ESMTPA id D8C7B36E1DD0; Mon, 27 May  
2024 17:49:33 +0300 (+03)
```

In case check fails, it is likely that the message is malicious

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

28

More sophisticated technologies

Authentication/validation technologies: MTAs should be able to assess whether the sender identified in an email message was the one who actually sent the message

Four different technologies can be deployed on Mail Servers:

- Sender Policy Framework (SPF)
- Domain Keys Identified Mail (DKIM)
- Domain-based Message Authentication, Reporting And Conformance (DMARC)
- Authenticated Received Chain (ARC)

These technologies complement anti-spam/malware filters

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

29

Sender Policy Framework

SPF is an open standard introduced in 2003 and standardized in 2006 to validate email messages and fight/avoid spoofing [[RFC 7208 “Sender Policy Framework \(SPF\) for Authorizing Use of Domains in Email, Version 1”](#) published in 2014]

It was originally inspired by the behavior of spammers who use random addresses to avoid receiving bounces and remain anonymous

It is a sender authentication protocol that focuses on the **message envelope**, i.e., email address specified in the **MAIL FROM** (corresponding to the **Return-path** header, different from the **From** displayed to the users)

It also provides support for the authentication of the SMTP **EHLO** argument (FQDN of sender's Mail Server)

It is based on the cooperation of sender and recipient MTAs

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

30

SPF implementation

Offline activities performed by domain owners:

- Define the sending policies associated with their domain (i.e., which Mail Servers can be used to send mail from the domain)
- Publish their policies in the DNS as a Resource Record of type **TXT**

Online activities performed by recipient Mail Servers:

- DNS queries to check whether the message complies with the sender policy specified by the domain owner
- Main outcomes of this check:
 - +Pass**
 - Fail**
 - ~Softfail**
 - ?Neutral**

The protocol does not specify the actions associated with failures

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

31

Sending policies: examples

Domain owners publish the sending policies for their domains, i.e., IP addresses allowed to send mail from their domains: Resource Records of type **TXT** associated with the domains

authorizes third-party services

```
univesitadipavia.it. 3600 IN TXT "v=spf1  
include:_spf.google.com mx -all"
```

IPs associated with the **MX** RR of the domain are allowed

any other IP is not allowed

```
gmail.com. 300 IN TXT "v=spf1  
redirect=_spf.google.com"
```

pointer to another domain name that hosts an SPF policy

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure

32

TXT Resource Records

```
_spf.google.com. 300 IN TXT "v=spf1  
include:_netblocks.google.com include:_netblocks2.google  
.com include:_netblocks3.google.com ~all"
```

any other IP allowed
but marked

Up to 10 levels of DNS recursion, i.e., no more than 10 references to other domains

```
_netblocks.google.com. 300 IN TXT "v=spf1  
ip4:35.190.247.0/24 ip4:64.233.160.0/19 ip4:66.102.0.0/2  
0 ip4:66.249.80.0/20 ip4:72.14.192.0/18 ip4:74.125.0.0/1  
6 ip4:108.177.8.0/21 ip4:173.194.0.0/16 ip4:209.85.128.0  
/17 ip4:216.58.192.0/19 ip4:216.239.32.0/19 ~all"
```

© M. C. Calzarossa 2026

Enterprise Digital Infrastructure